Middlesex University Dubai

MSc -Data Science and AI

CST4235

Ethics, Privacy and Security in Data Science and AI

ASSIGNMENT

"WANNACRY – A RANSOMWARE ATTACK THROUGH THE LENS OF DATA SCIENCE AND AI"

Kusum Anil Vishwakarma

MISIS ID: M01093046

INSTRUCTOR: DR. IKRAM UR REHMAN

Declaration of Authorship and AI Use

I confirm that this coursework is entirely my own work and that I have not plagiarised or copied material from any source.

All sources of information used have been properly acknowledged in the references section, and no part of this work has been submitted for assessment elsewhere.

I further confirm that I have not used AI tools for content generation in this coursework.
If AI tools were used, they were used responsibly and only to support minor tasks such as improving clarity or checking grammar.

Table of Contents

Abstract

Summary of the WannaCry attack, relevance to AI ethics, privacy, and security.

1. Introduction and Background
1.1 Overview of the WannaCry Attack
1.2 Relevance to Data Science and AI
1.3 Key Stakeholders
1.4 Research Questions

2. Method and Evidence Base
2.1 Data Sources and Literature Selection
2.2 Legal and Standards Frameworks Used
2.3 Analytical Approach

3. Ethical Analysis
3.1 Ethical Dilemmas and Failures
3.2 Accountability and Governance
3.3 Transparency and Explainability
3.4 Fairness and Stakeholder Impact
3.5 Respect for Human Autonomy

4. Privacy Analysis
4.1 Sensitive Data and GDPR Compliance
4.2 Data Minimisation and Storage Practices
4.3 Lack of Privacy-by-Design
4.4 Consent and Patient Rights

5. Security Analysis
5.1 Technical Vulnerabilities
5.2 Patch Management and Secure Engineering
5.3 Network Segmentation and Access Control
5.4 Incident Response and Monitoring
5.5 Cryptographic Controls

6. Integrated Discussion
7. Technical and Governance Mitigations

8.Reflection

ABSTRACT

The WannaCry ransomware attack (2017) is one of the major disruptive global data lock incidents, severely affecting healthcare, transportation, telecommunications and several other public services. However, the most affected is UK National Health Service (NHS), as over 19,000 appointments were cancelled and critical systems rendered inaccessible. Although WannaCry directly did not employ Artificial Intelligence, the attack however exposes systemic ethical, privacy and security challenges highly relevant to Data Science and AI-driven infrastructures. This case study deeply analyses WannaCry through established frameworks including GDPR (EU ,2016), NIST Cybersecurity frameworks (2018), IEEE ethically aligned design (2019), and ACM Code of Ethics (2018). Using academic literature, government reports and technical analyses, this case study identifies major vulnerabilities which includes insufficient patching, weak governance, poor data stewardship and inadequate accountability structures. The provided analysis reveals the interconnection of failures in ethical decision making, privacy protection, and data security specifically regarding patient's data confidentiality and organisational responsibility. The case study argues that the attack demonstrates how any data-driven or AI-enabled ecosystem is as secure as its underlying cyber infrastructure. The findings highlight the need for healthcare organisations to adopt integrated ethical and security frameworks to manage risks in increasingly AI – reliant systems.

Keywords: healthcare security, privacy protection, patient data confidentially, organisational governance, AI enabled healthcare, GDPR compliance, NIST Cybersecurity frameworks Ethically Aligned Design, ACM code of ethics, digital health systems, data science governance.

INTRODUCTION AND BACKGROUND: A DATA SCIENCE AND AI LENS

The WannaCry Ransomware attack May 2017 which represented a critical failure of global digital infrastructure while also exposing the vulnerability of modern data-driven and Ai – enabled healthcare systems. This malware not only weakened Microsoft's SMBv1 protocol but was also responsible for enabling it to spread across connected networks (Microsoft,2017). Over 230,000 systems in more than 150 countries were infected due to this attack. The UK National Health Service (NHS) suffered widespread system shutdowns, cancelled surgeries, delayed diagnoses, and loss of excess patient's data (NAO,2017).

From a Data Science perspective, healthcare is now heavily dependent on large scale data processing, predictive analysis and machine learning models for clinical decision making, hospital resource optimisation and patient risk prediction. These systems rely entirely on the continuous availability, integrity and security of data pipelines. When WannaCry encrypted hospital databases it not only disables computers – it disrupted the entire AI driven healthcare ecosystems (Sittig & Singh, 2016).

From an Artificial Intelligence perspective, many hospitals used early-stage AI tools for scheduling, diagnostics and workflow automation. These AI systems became instantly unreliable because their training data, inference inputs and model repositories were locked or corrupted by ransomware.

Important stakeholders like patients, clinicians, data scientists, hospital IT departments, policy makers, cybersecurity agencies, and technology vendors. Patients faced treatment delays and increased safety risks, clinicians lost access to critical decision-support tools, and data teams lost system visibility and model reliability. In order to access their own databases, initially they were asked for a ransom amount which worth approximately $300 in bitcoin to receive the decryption key which not paid within three days would then ask for $600 in bitcoin (1 bitcoin = $92,713.00), also in case of no payment, the encrypted files would permanently be deleted. This payment structure created psychological pressure on victims like the large organizations like big government hospitals, agencies and private companies.

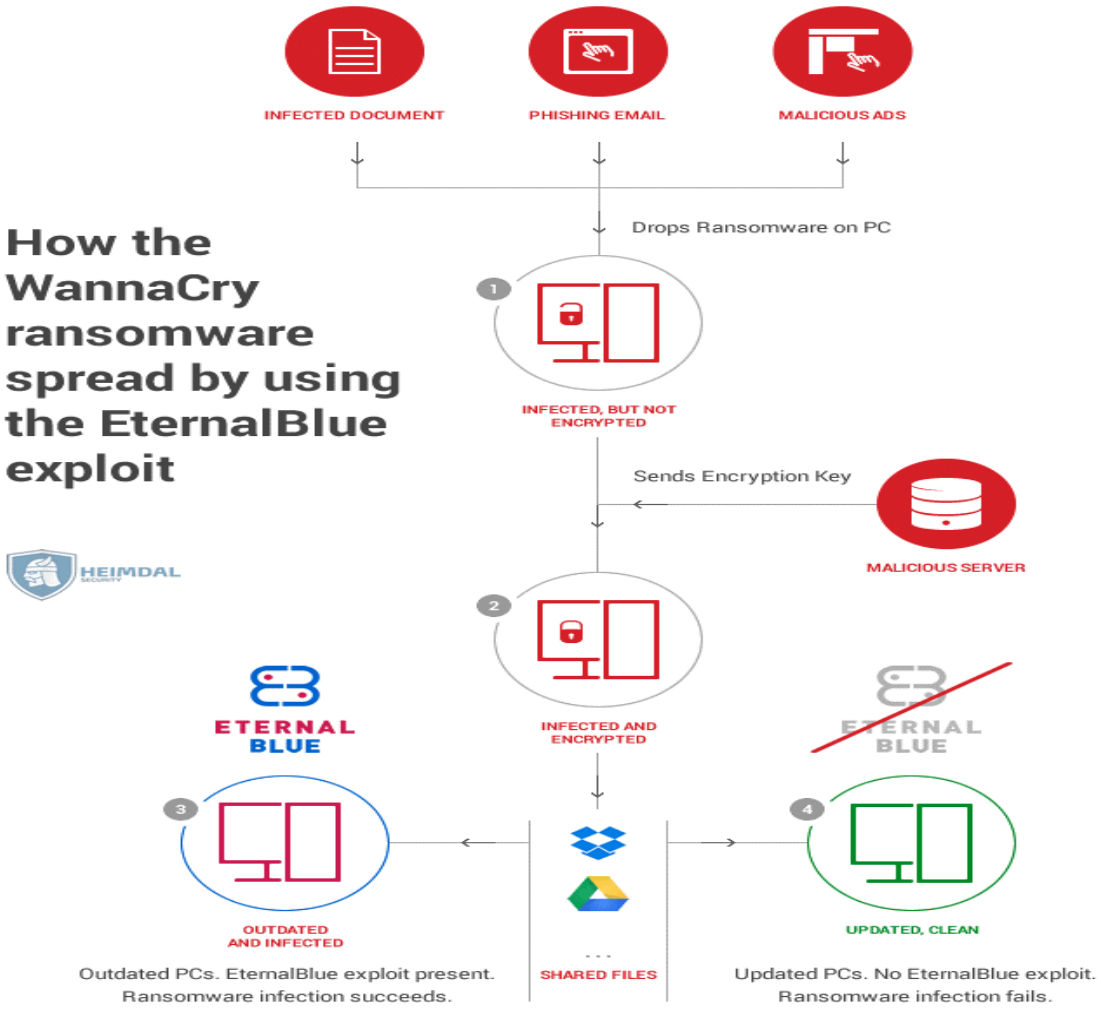

FIGURE 1: WannaCry Ransomware Propagation via the Eternal Blue Exploit.

This figure gives a detailed description about how the infection chain was carried out during the WannaCry ransomware attack. The process begins with user interacting with malicious content like phishing emails, infected document or fake advertisements, which initiated the introduction of ransomware in the systems. After the initial infection the malware contacts the remote malicious server to obtain encryption key, enabling the device to become fully encrypted. The diagram further illustrates how WannaCry spreads laterally across the networks using Eternal Blue in outdated SMBv1 services. Unpatched or outdated systems become rapidly infected, while updated systems with MS17-010 patch prevented the exploitation and further blocked the ransomware from propagating in their updated systems.

The WannaCry attack is therefore not only a cybersecurity case but also a failure of data science governance and AI risk management. This case study addresses the following questions from a data science and Ai view.

- How did failures in GDPR principles such as availability, minimisation, and privacy by design contribute to the severity of the impact?
- How did weaknesses in data pipelines, legacy systems and storage practices undermined the reliability of AI driven healthcare tools?
- How can AI, data governance frameworks and security engineering can be accumulated together to prevent the similar large-scale future ransomware attacks.
- How can inequalities in digital systems result in unequal recovery and fairness which is accessible to the services?
- What does WannaCry reveal about the dependence of AI ecosystems on secure underlying infrastructure?
- How did outdated SMBv1 systems, weak patch management, insufficient cryptographic controls enable widespread disruption among the systems.
- How could machine learning-based intrusion detection or behaviour analytics have minimised the effect of the attack?

1. METHOD AND EVIDENCE BASE

This case study adopts an evidence-based analytical approach using authoritative academic and professional sources. Peer-reviewed literature was obtained from IEEE Xplore, ACM Digital Library, Elsevier ScienceDirect, and Google Scholar, focusing on cybersecurity, AI governance, healthcare data protection, and ransomware forensics. Credible institutional reports were sourced from UK National Audit Office (2017), NHS Digital (2018), Europol (2018), NCSC (2017), and Microsoft Security Bulletins.

Legal and standards-based evidence was drawn from the General Data Protection Regulation (EU 2016), the NIST Cybersecurity Framework (2018), ISO/IEC 27001, ISO/IEC 27701, IEEE Ethically Aligned Design (2019), ACM Code of Ethics (2018). These frameworks were selected because they represent globally recognised standards for secure and ethical data processing, AI governance, and risk management.

Evidence evaluation followed credibility and relevance criteria, ensuring that each claim is supported by peer-reviewed research or official documentation. Textbooks, unofficial blogs, or unverified online commentary were excluded, consistent with the assignment guidelines. The ethical analysis employs principlism, accountability framework, and stakeholder impact assessment. Privacy evaluation draws on GDPR principles, while security analysis uses NIST and ISO frameworks. Together, these methodological choices ensure alignment with scientific rigor and professional standards.

2. ETHICAL ANALYSIS

The WannaCry attack exposed several ethics failures rooted in governance, organisational responsibility, and risk management. From an AI and Data Science perspective, ethical governance requires maintaining the integrity, availability and security of data that supports machine learning models and clinical decision-support systems.

3.1 ETHICAL DILEMMAS AND FAILURES

The NHS National Audit Office (2017) reported that critical systems were running outdated Windows versions without necessary security patches this issue was classified by the UK NCSC as a "preventable vulnerability" (NCSC,2017). This describes an ethical lapse in due diligence, violating principles of responsible, data stewardship and beneficence, as secure systems essential for preventing harm to patients.

The shutdown of diagnostic systems, including those used for cancer screening and medical imaging, directly impacted patient welfare. Ethical theories such as consequentialism emphasize preventing foreseeable harms; given that a Microsoft patch (MS17-010) existed months before the attack, the failure to implement it represents a breach of reasonable care (Microsoft,2017).

3.2 ACCOUNTABILITY AND GOVERNANCE

The ACM Code of Ethics (2018) stresses professional responsibility, transparency, and proactive mitigation. In this case, under accountability structures within NHS organisations contributed to delays in patch management. GDPR's principle of accountability (ARTICLE 24) requires data controllers to implement "appropriate technical and organisational measures" for secure processing. The NHS's fragmented digital architecture made consistent patching difficult, revealing a governance weakness inconsistent with modern AI system management, where clear accountability is fundamental (IEEE,2019).

3.3 TRANSPARENCY AND EXPLAINABILITY

Although WannaCry is not an AI system, its impact highlights ethical concerns related to transparency and traceability in digital ecosystems. AI ethics framework (IEEE, 2019; Floridi & Cowls, 2019) highlight that explainability is essential, not only in algorithmic outputs but also in systems infrastructure, incident response processes and risk communications. Many NHS trusts lacked comprehensive asset inventories, making it difficult to identify compromised systems. This “lack of explainability of infrastructure” mirrors transparency challenges in AI systems, underscoring this ethical need for traceable, interpretable systems architectures.

3.4 FAIRNESS AND STAKEHOLDERS IMPACT

Due to this Ransomware attack, it disproportionately affected vulnerable populations who completely rely on public healthcare services. Ethical fairness requires that digital health services are reliable and equitable. The cancellation of over 19,000 appointments and even the diversion of ambulances constituted significant harm. AI – dependent departments including radiology, oncology, and emergency care experienced operational paralysis.

Digital inequalities were also very significant, well-funded hospitals with modern IT infrastructures recovered faster than underfunded units, highlighting disparities in resilience (Bada et al., 2019). Ethical frameworks like justice and fairness stress needed to ensure technological reliability which does not satisfy disadvantaged particular groups.

3.5 RESPECT FOR HUMAN AUTONOMY

Ethical AI frameworks emphasise preserving human autonomy in making digital decisions. During WannaCry, clinicians were forced to revert to manual processes, handwritten notes, and offline workflows. This not only makes safe clinical decision making but also illustrates how poor digital ethical practices can comprise autonomy by removing accessible tools that support informed decisions (IEEE,2019).

3.6 CONSENT AND PATIENT RIGHTS

Even though Ransomware does not involve consent violations, unavailability of systems disrupted patient's rights under GDPR (Articles 15 – 18) including right to access, rectification, and restriction of processing. Patients were not able to access their health information or exercise data rights during the incident, demonstrating how weak cybersecurity undermines privacy rights even without data theft.

FIGURE 2: SUMMARY TABLE FOR ETHICAL ANALYSIS:

Ethical Issue	**Short Summary**
Ethical Failures	Outdated, unpatched NHS systems caused preventable harm and disrupted critical services.
Accountability	Weak governance and unclear responsibility led to slow patching, violating GDPR/ACM standards.
Transparency	Poor asset visibility and system traceability hindered incident response.
Fairness	Vulnerable patients were most affected; digital inequality caused uneven recovery.
Autonomy	Clinicians lost digital tools, forcing manual work and reducing decision-making support.
Patient Rights	System outages blocked GDPR rights such as access and correction of health data.

4.PRIVACY ANALYSIS

The WannaCry incident raised substantial privacy concerns as patient's data, although not exfiltrated, became inaccessible due to encryption of clinical systems. GDPR emphasises the principles of confidentially, integrity, and availability, all integral to privacy protection. Article 32 specifically mandates "appropriate technical and organisational measures" to ensure security of personal data, including protection against "accidental or unlawful destruction ". WannaCry caused unlawful destruction of accessibility, violating the availability component of privacy.

4.1 SENSITIVE DATA AND GDPR COMPLIANCE

The affected NHS system consisted of highly sensitive personal data, including health records, diagnostic images, prescriptions, and emergency response details. GDPR classifies health data as Special Category Data (Article 19), requiring enhanced protection. The NAO (2017) confirmed that inadequate patching and unsupported operating systems were widespread placing the patient's data at high privacy risks.

4.2 DATA MINIMISATION AND STORAGE PRACTICES

Outdated systems often retain unnecessary legacy data, violating GDPR principles of data minimisation and storage limitation. NHS Digital's post incident review highlighted that several trusts lacked up to date data retention policies, meaning older systems stored far more patient information than operationally necessary. This increased the privacy impact of attack.

4.3 LACK OF "PRIVACY BY DESIGN"

GDPR Article 25 mandates privacy by design and default. The absence of systematic vulnerability management, encryption of data at rest, and robust network segmentation demonstrates failures in embedding privacy protections into system architecture. Privacy by design in AI systems requires end to end security, yet WannaCry revealed infrastructural weakness that would compromise any AI services depending on those systems.

FIGURE 3: SUMMARY TABLE FOR PRIVACY ANALYSIS:

Privacy Issue	**Short Summary**
Privacy Impact	Patient data remained confidential but became inaccessible, violating GDPR's availability requirement under Article 32.
Sensitive Data & GDPR Compliance	NHS systems held Special Category health data; outdated, unpatched systems placed this data at high privacy risk.
Data Minimisation & Storage	Legacy systems stored unnecessary patient data, breaching GDPR minimisation and storage limitation principles.
Lack of Privacy by Design	Weak vulnerability management, poor segmentation, and limited embedded protections showed failure to meet GDPR Article 25 requirements.

5. SECURITY ANALYSIS

WannaCry is a fundamental example of security failure with implications for AI – enabled systems. The analysis NIST, ISO and cybersecurity are the best practices to know about the security failures in WannaCry ransomware attack.

5.1 TECHNICAL VULNERABILITES

This attack exploited a well-known weakness in the outdated (SMBv1) protocol which used the Eternal Blue exploit. Even though Microsoft already released patch (MS17-010) weeks before the attack, many systems especially NHS remained unpatched. This ignorable gap was able to get clarity about weakness of patch management. The (UK NCSC,2017) later on illustrated this attack as "highly preventable, "which highlighted a clear breakdown in even basic security practices that is a fundamental beginning of (NIST CSF) functions- Identify, Protect, and Respond**.**

5.2 PATCH MANAGEMENT AND FEATURE ENGINEERING

(ISO/IEC 27001 Annex A.12.6) clearly relies on the importance of consistent vulnerability management, yet many NHS trust lacked in a centralising patching process. This raises a concern relating to the security reasons to undermine secure engineering principles that is dependent completely upon modern AI systems. AI functions depend on a stable, uncompromised data pipelines, if a ransomware attacks these pipelines than the functionality would gradually collapse regardless of the model quality.

5.3 NETWORK SEGMENTATION AND ACCESS CONTROL

WannaCry's lateral movement which was so rapid that it exposed a lack of effective network segmentation across affected systems. A modern Zero trust model which is now recommended in AI and cybersecurity architectures were completely absent at that time (NIST SP 800-207). Poor access controls and overly permissive internal networks created an environment, due to which

there was a malware spread unchecked, and demonstrated how insufficient access management can amplify the scale of the attack.

5.4 INCIDENT RESPONSE AND MONITORING

(NIST CSF) emphasises continuous monitoring and rapid detection. However, organisations lacked automated intrusion detection systems capable of recognising unusual SMB traffic. Modern AI based anomaly detection AI tools could have also mitigated spread, underscoring the need for machine learning enhanced cybersecurity.

5.5 CRYPTOGRAPHIC CONTROLS

WannaCry encrypted data using strong (AES AND RSA) algorithms, but many NHS systems did not encrypt sensitive data at rest. (ISO/IEC 27001) recommended encryption to reduce the impact during the compromised database.

FIGURE 4: SUMMARY TABLE FOR SECURITY ANALYSIS:

Security Issue	Short Summary
Technical Vulnerabilities	Exploited outdated SMBv1 via Eternal Blue; missing MS17-010 patch showed weak patch management and failure of basic NIST CSF practices.
Patch Management & Secure Engineering	NHS lacked centralised patching; violated ISO/IEC 27001 vulnerability management and threatened AI-dependent data pipelines.
Network Segmentation & Access Control	Poor segmentation and permissive networks enabled rapid spread; absence of Zero Trust principles increased impact.
Incident Response & Monitoring	Limited monitoring and no automated detection of unusual SMB activity; AI-based anomaly tools could have reduced spread.
Cryptographic Controls	NHS systems lacked encryption at rest; non-compliance with ISO/IEC 27001 encryption controls worsened the impact of ransomware.

6. INTEGRATED DISCUSSION

The ethical, privacy, and security of WannaCry are deeply interconnected. Ethical analysis lapses in governance particularly and risk in the assessment which is directly precipitated privacy and security failures. Poor cybersecurity undermined organisational accountability, violating GDPR obligations and eroded public trust.

Security failures created privacy harms – the encryption of clinical data prevented lawful access, representing an availability breach under (GDPR 32). In healthcare, data access is critical for invading patients' safety and continuity to care, when the clinicians cannot retrieve patients' history, diagnosis or treatment plans, this can result in delayed care or misinformed decisions, thus making security breach a privacy violation in practice, even without data loss.

Privacy failures like inadequate minimisation and retention controls which accelerated the impact. This aligns with the research on secure system design that emphasizes minimising attack surface through controlled data storage and lifecycle policies (Quazi et al.,2024).

Ethical failures such as inadequate transparency about system vulnerabilities and insufficient oversight, set the stage for the widespread failures.
This transparency issue echoes concerns raises in AI to identify and mitigate risks systematically.

Data Science and AI revealed how deeply it can depend on secure, resilient infrastructures. When NHS systems went offline, AI based diagnostic tools, predictive analytics platforms and other digital technologies were instantly rendered useless. This demonstrated that ethical AI completely depend upon strong digital security foundations and cannot function without. Scholars such as Floridi & Taddeo (2016) stress on the importance of integrating ethical thinking with the robust cybersecurity and privacy engineering.

7. TECHNICAL AND GOVERNANCE MITIGATIONS

Evidence bases Technical and governance measures are very essential in order to mitigate the future attacks which can be summarised as follows: -

TECHNICAL MITIGATIONS:

- A basic technical action is implementation of automated patch management aligned with ISO/IEC 27001 and the NIST cybersecurity frameworks.
- Also, ensuring all the systems receive and apply critical updates like the MS17-010 patch that could prevent WannaCry's attack from propagating and reducing known vulnerabilities exposure which also aligns with the security management practices.
- Architecturally, Zero Trust models which assume no trust between network elements limit ransomware's lateral movement, and also enforces stricter access controls and micro-segmentation which security research shows reduction in malware spread.
- Encryption is the key control to privacy integrated security frameworks and directly supports GDPR's confidentiality requirements.

GOVERNANCE MITIGATIONS

- Regular Ethics and cybersecurity audits help organisations continuously assess risk exposure and compliance with GDPR professional codes like ACM code of ethics.
- Establishment of clear accountability structures ensures ownership of cybersecurity and data governance responsibilities at organisational and departmental levels.
- Fragmented responsibility contributed to delays in patching within NHS services, clearly defining roles ensure timely response and also reinforces the ethical and legal frameworks under GDPR.

8.REFLECTION

The WannaCry case deepened my understanding of the interdependency between ethics, privacy, and security in Data Science and AI. Also, previously reviewing cybersecurity as primary technical, however this incident demonstrated that it is fundamentally an ethical obligation. The attack also broadened my knowledge about privacy under GDPR, showing that the availability failures can constitute privacy violations. With further analysis, there was a clear idea related to AI which directly depends on secure infrastructure. Ethical AI not only is about fairness, transparency or bias mitigation but also requires strong governance, risk assessment and cybersecurity basics. The case aligns with professional expectations for data scientist to maintain public trust and prevent harm. It also highlighted the foundational role of secure infrastructure in supporting AI systems. Under developed infrastructure undermine these systems regardless of model accuracy or algorithms used, reaffirming that responsible AI is inseparable from the robust security and governance frameworks. I was specially struck by how a breach that did not involve data theft cools still cause a privacy violation. GDPR's inclusion of availability and integrity as core privacy violation was an important lesson, when the ransomware made the records unable to use, it violated patients right just as surely as leak would do. This broadened my view of privacy and ethical lessons beyond confidentiality alone.

Overall, the WannaCry incident taught me that ethical data science practice involves safeguarding systems and people together. Also, maintaining public trust requires not only fair but also transparent models which are secure, resilient and well governed technical ecosystems that protect individuals and uphold legal and professional standards.

PROVIDED BELOW IS THE LINK TO THE VIDEO HIGHLIGHTING POLICY RECOMMENDATIONS FOR "WANNACRY – RASOMWARE ATTACK THROUGH LENS OF DATA SCIENCE AND AI" INCLUDING ETHICS, PRIVACY AND SECURITY FOR THE SAME.

https://youtu.be/WMByH5bh_Go?si=_Pxj6T1-yp_xMJ7x

REFERENCES

ACM (2018). ACM Code of Ethics and Professional Conduct.
Code of Ethics

Bada, S., Sasse, A., & Nurse, J. R. C. (2019). Cybersecurity awareness in critical sectors: A review of challenges and opportunities. Computers & Security, 87, 1–12.
Blockchain smart contracts formalization: Approaches and challenges to address vulnerabilities - ScienceDirect

Europol (2018). Internet Organised Crime Threat Assessment (IOCTA). European Union Agency for Law Enforcement Cooperation.
Internet Organised Crime Threat Assessment 2018 | Europol

European Union (2016). General Data Protection Regulation (GDPR). Official Journal of the European Union.
Regulation - 2016/679 - EN - gdpr - EUR-Lex

Floridi, L., & Taddeo, M. (2016). What is data ethics? Philosophical Transactions of the Royal Society A, 374(2083).
What is data ethics? | Philosophical Transactions of the Royal Society A | The Royal Society

Floridi, L., & Cowls, J. (2019). A unified framework of five principles for AI in society. Harvard Data Science Review, 1(1).
A Unified Framework of Five Principles for AI in Society · Issue 1.1, Summer 2019

IEEE (2019). Ethically Aligned Design: A Vision for Prioritizing Human Well-being with Autonomous and Intelligent Systems.
IEEE SA - Autonomous and Intelligent Systems (AIS)

ISO/IEC (2013). ISO/IEC 27001: Information Security Management Systems.
ISO/IEC 27001:2022(en), Information security, cybersecurity and privacy protection — Information security management systems — Requirements

ISO/IEC (2019). ISO/IEC 27701: Privacy Information Management Systems.
ISO/IEC 27701:2025(en), Information security, cybersecurity and privacy protection — Privacy information management systems — Requirements and guidance

Microsoft (2017). Security Bulletin MS17-010: Critical Update for Microsoft Windows SMB Server.

Microsoft Security Bulletin MS17-010 - Critical | Microsoft Learn

National Audit Office (2017). Investigation: WannaCry Cyber Attack and the NHS. UK Government.
Investigation: WannaCry cyber attack and the NHS - NAO report

NCSC (2017). WannaCry Malware Attack: NHS Incident Report. National Cyber Security Centre.
Investigation: WannaCry cyber attack and the NHS - NAO report

NHS Digital (2018). Lessons Learned Review: WannaCry Ransomware Attack.
Investigation: WannaCry cyber attack and the NHS - NAO report

NIST (2018). Framework for Improving Critical Infrastructure Cybersecurity.
The NIST Cybersecurity Framework (CSF) 2.0

Quazi, M., Islam, R., Rahman, M. M., Azad, M. A. K., & Chakraborty, S. (2024). Machine-learning-based anomaly detection in healthcare IT security. Healthcare Analytics, 4, 1–12.
Malware analysis and detection using data mining and machine learning classification - Charles Sturt University Research Output

Sittig, D. F., & Singh, H. (2016). A socio-technical approach to preventing, mitigating, and recovering from ransomware attacks. Applied Clinical Informatics, 7(2), 512–527.
Sci-Hub. A Socio-technical Approach to Preventing, Mitigating, and Recovering from Ransomware Attacks / Applied Clinical Informatics, 2016